LeadPilot AI
Functional Specification

System behavior data contracts and acceptance criteria

Version 1.0 | 5 October 2026 | LP FSD 001

Prepared for product stakeholders, agency pilot partners, and the delivery team.

Review status: proposed product baseline. Complete approval records and unresolved decisions before treating this specification as a release commitment.

Document control	Value
Product	Multi tenant AI lead management and follow up for UAE real estate agencies
Document owner	Product Owner role to be assigned
Companion	LP BRD 001 Business Requirements Document
Change control	Versioned requests with scope, risk, cost, and acceptance impacts
Approval	Sponsor, agency representative, engineering lead, security and privacy reviewers

Contents

1 Purpose and conventions 3
2 Architecture and deployment 3
3 Identity tenancy and permissions 3
4 Navigation and common behavior 4
5 F 03 Lead intake 5
6 F 04 Lead inbox and lifecycle 5
7 F 05 Conversation and notes 6
8 F 06 AI analysis 6
9 F 07 Reply suggestions 8
10 F 08 Follow ups 8
11 F 09 Dashboard 9
12 F 10 Notifications and F 11 Team 9
13 F 12 Audit and F 13 Privacy 9
14 F 14 Reliability and error handling 10
15 Data model and ERD 11
16 API contracts 13
17 Validation and configuration 14
18 End to end workflows 15
19 Roadmap specification 15
20 Acceptance tests and traceability 16
21 Delivery readiness and open decisions 18
22 Technical references and approval 19

Use Word navigation headings to move between sections. Update the contents field after editing.

1 Purpose and conventions

This FSD defines MVP behavior and extension points for LeadPilot AI, alongside LP BRD 001. F 01 to F 14 are MVP requirements. F 15 to F 17 are roadmap only. A 01 to A 24 are minimum acceptance evidence. SHALL indicates required behavior; proposed configurable limits require approval. Roles belong to agency memberships, not global users.

2 Architecture and deployment

Use a modular monolith: Next.js 16 App Router React TypeScript Tailwind/shadcn React Hook Form and shared Zod validation. Route Handlers expose JSON APIs; Server Actions call the same domain services. Supabase Auth supplies identity, PostgreSQL stores business records, RLS restricts access, Responses API runs server side, and Vercel hosts web and bounded cron calls.

Modules: identity and tenancy, leads, conversations, AI orchestration, follow ups, notifications, administration, audit, usage. PostgreSQL durable job rows and transactional outbox support bounded workers. Do not rely on requests continuing after response or in memory queues surviving deployment.

Layer	Responsibility	Boundary
Browser	Forms, role aware UI, job and error states.	Not tenant or permission authority.
Next.js server	Verify session and membership, authorize, validate, run domain transaction.	Server secrets; every mutation rechecked.
Supabase database	RLS, constraints, storage, leases.	Authenticated user scope; narrow privileged jobs.
AI adapter	Minimized context, Responses call, schema check, usage and result.	No tools browsing or unrelated retrieval.
Scheduler	Protected bounded scans and workers.	Recoverable work; not precise delivery guarantee.

Separate development, staging, and production projects and credentials. Preview data is deidentified. Sensitive responses use no public shared caches; any cache includes tenant and visibility scope and invalidates on membership changes. Pin versions after compatibility review; review migrations and rollback.

3 Identity tenancy and permissions

3.1 F 01 Access and onboarding

MVP uses verified email and password with Supabase Auth reset and verification flows and approved transactional email delivery. User without membership may create agency or accept invitation. Agency create is idempotent and atomically creates exactly one owner. Fields: agency name 2 to 120 characters, IANA timezone default Asia/Dubai, locale en. Checklist: agency details, approved processing settings, invite, sample lead and reminder.

Multiple memberships require active agency choice. Switching clears tenant cached data and filters; every server request revalidates membership. Invitations store hashed single use token, proposed 72 hour expiry and normalized email. Valid acceptance requires same verified email and atomically consumes token. Resend revokes prior token. Pending invites reserve seats; expiry releases them. Failure reveals no other agency or account information.

3.2 F 02 Authorization

Tenant is resolved from verified membership or integration credential; payload tenant selector is not authority. RLS checks active membership on tenant tables. AGENT can access only currently assigned leads and children. Database membership checks prevent disabled membership remaining active until JWT expiry.

Operation	OWNER	ADMIN	AGENT
Lead read search edit status	All agency	All agency	Assigned only
Manual lead create	Yes	Yes	Self assigned
Import and intake credentials	Yes	Yes	No
Assignment	Yes	Yes	No
Messages AI drafts and tasks	All agency	All agency	Assigned lead and own task
Dashboard	Agency	Agency	Assigned scope
Archive restore	Yes	Yes	No
Manage AGENT members	Yes	Yes	No
Manage ADMIN members	Yes	No	No
Transfer owner and agency close	Yes	No	No
Agency and AI settings	Yes	Yes except owner only	No
Commercial status	Yes	No	No
Business audit read	Agency	Agency	Assigned lead
Notifications	Own recipient	Own recipient	Own recipient

ADMIN cannot promote self or manage ADMIN or OWNER. Owner transfer requires recent authentication and active target; atomically promote target and demote old owner to ADMIN. Last owner cannot leave or be disabled. No user may write audit, choose creator identity, change tenant_id or bypass role checks through direct database access. Support has no default tenant content access.

4 Navigation and common behavior

Navigation: Dashboard, Leads, Follow ups, Notifications, Settings. Settings: My profile, Team, Agency, Integrations, owner only Pilot plan. Lead detail: Overview, Conversation, AI, Follow ups, Activity. Hide unavailable actions and enforce authorization server side.

- Responsive layouts, keyboard focus, labels, accessible dialogs, explicit loading and empty states.
- Agency timezone shown on dates; persistence UTC. Currency code displayed with grouped amounts.
- Save pending and success states; failures preserve input. Confirm destructive actions and owner transfer.
- Cursor pagination default 25 maximum 100 with stable id tie breaker. Filters URL shareable without secrets.
- Mutable records use expected_version; stale writes return conflict and preserve local draft for compare or reload.

5 F 03 Lead intake

5.1 Manual entry

Require full_name and valid email or phone. Optional: initial_message intent budget_min budget_max currency budget_period locations property_type bedrooms purchase_timeline source and notes. Managers choose active assignee or unassigned; AGENT creates self assigned. Create sets NEW, MANUAL, server creator and times. Initial message becomes INBOUND in same transaction.

Tenant scoped exact normalized contact match returns a candidate warning, never overwrites. Managers open existing or create separate with reason. AGENT sees only accessible candidates; inaccessible match produces generic manager review flag and self assigned new lead without revealing identity. Match keys: case insensitive normalized email or international phone. No fuzzy identity verification or automatic merging.

5.2 CSV import

Managers upload UTF 8 CSV, proposed maximum 5 MB and 1,000 rows. Provide header template, mapping, and 20 row preview. Columns mirror create; assignee_email must match active member. Reject tenant, creator identity, and role columns rather than accepting caller authority. Duplicates skipped by default; manager can create separate with batch reason.

Validate all rows first and show row field and reason. Confirmed import processes valid rows in bounded transactions; invalid rows do not block valid rows. Durable import_id and row_index uniqueness prevents duplicate replay. Show created duplicate failed counts reconciling to input total and permit retry of retryable failures only. Raw file removed after processing under approved policy. Formula like values remain text and future exports must sanitize them.

5.3 Website webhook

POST /api/v1/intake/{integration_id}/leads verifies HMAC SHA 256 over timestamp and raw body, proposed five minute skew, unique external_event_id, active integration and limit. Integration maps to tenant; reject payload tenant creator and arbitrary assignment. Configured active default assignee or manager queue. Source WEBSITE includes source reference ingestion time and supplied customer message time.

Secret shown once to manager, stored encrypted with server key, rotatable and revocable with key version. Do not embed signing secret in browser JavaScript: website backend signs. Browser only form intake is a later protected design. Idempotency key (tenant integration external_event_id) and body hash: identical replay returns original result; changed payload returns 409. Duplicate contacts create review flagged lead without merging. 201 create, 200 replay, 422 invalid, 401 signature failure, 429 limits, 503 temporary failure. Sender retries transient failures with same event id.

6 F 04 Lead inbox and lifecycle

Inbox: name contact summary source assignee status current score and stale indicator temperature next task. Filters: status assignee source created range score do not contact due task duplicate review archive. Search name and authorized contacts. Managers see unassigned queue. Detail presents facts, needs, analysis and timeline.

Status	Meaning	Allowed next
NEW	Captured with no logged contact.	CONTACTED QUALIFIED FOLLOW_UP LOST
CONTACTED	Logged outbound attempt.	QUALIFIED FOLLOW_UP WON LOST

Status	Meaning	Allowed next
QUALIFIED	Human confirmed intent and sufficient needs.	CONTACTED FOLLOW_UP WON LOST
FOLLOW_UP	Open next action.	CONTACTED QUALIFIED WON LOST
WON	Human recorded commercial success.	Reopen CONTACTED or QUALIFIED with reason
LOST	Active pursuit ended with reason.	Reopen NEW or CONTACTED with reason

CONTACTED requires outbound message or contact attempt. QUALIFIED requires confirmed intent and qualification summary; unknown budget or area explicitly acknowledged. FOLLOW_UP requires OPEN task. WON requires won_at not future and outcome summary; optional nonnegative deal value with currency. LOST reason: NO_RESPONSE NOT_INTERESTED BUDGET_MISMATCH ALREADY_CLOSED DUPLICATE OTHER, with text for OTHER. Changes are explicit and version checked.

Terminal transition previews task cancellations and commits outcome, cancellations and audit together. Temperature independent: proposed HOT score 80 to 100, WARM 50 to 79, COLD 0 to 49, UNKNOWN without analysis; manual override requires reason. Score never changes lifecycle or assignment.

Archive sets archived_at, hides default counts, and cancels tasks; managers can restore. Restore preserves previous lifecycle and does not recreate tasks. Reopen terminal state before outreach. Do not contact is independent; editable user can set it, cancelling outreach tasks and blocking drafts. Clearing requires manager and documented basis. INTERNAL tasks remain permitted for privacy handling.

7 F 05 Conversation and notes

Text timeline per lead stores direction INBOUND OUTBOUND INTERNAL, channel MANUAL WEBSITE or future adapter, body, occurred_at, created_at, author and provenance. WEBSITE input is inbound. Manually logged outbound delivery status is USER_REPORTED, never delivered or read. Internal notes are visually distinct and excluded from AI context by default.

Agent logs incoming text, external contact attempt or actual outgoing reply. Mark as contacted writes explicit outbound event and proposes CONTACTED for confirmation. Manual message edits store revisions and audit; provider supplied messages are immutable. Order occurred_at then created_at then id. New or edited customer text increments context_version and marks analysis stale. Escape HTML, safe links only; no attachments sync or unsupervised sends. Reject future timestamps; historical import is allowed with source label.

8 F 06 AI analysis

8.1 Jobs context and freshness

Analyze requires access, active lead, approved processing settings, tenant AI enabled, rate and quota capacity. Atomically reserve usage and queue durable job. Snapshot confirmed fields and latest customer messages only; omit contacts internal notes audits unrelated leads sensitive documents. Proposed 12,000 character cap sets truncation flag. Persist input_version and request hash.

Call Responses API server side with schema constrained output and store false baseline. This is not zero retention assurance; approve provider processing separately. No tools browsing or external retrieval. Quoted messages are untrusted data, not application instructions. Zod validates every returned field. Refusal or incomplete output becomes explicit safe failure, not forced plausible result.

Job states QUEUED RUNNING SUCCEEDED FAILED CANCELLED. Database lease and expiry claim bounded work. Retry transient timeout rate limit or service failure up to 3 total attempts with backoff and jitter. Schema failures do not loop indefinitely. Unique job result prevents repeated save. If context_version changes, retain result as STALE without promoting current pointer. Lost leases are recoverable. Cancellation or deactivation is rechecked before publishing result.

8.2 Structured result

Field	Type and content	Validation
schema_version language	Supported version; language code or unknown.	Exact schema compatibility.
summary	Plain text up to 1,000 characters.	Supported facts only.
intent	BUY RENT SELL INVEST OTHER UNKNOWN.	Unknown when unsupported.
budget	Nullable min max currency period MONTH YEAR TOTAL UNKNOWN.	Nonnegative; min <= max; no silent rental conversion.
needs	Up to 5 locations, type, nullable bedrooms and timeline.	Missing fields null or UNKNOWN.
next_step_requested	VIEWING CALLBACK OTHER NONE UNKNOWN with exact source evidence.	Score only explicit customer requests.
urgency	HIGH MEDIUM LOW UNKNOWN with evidence.	Expressed timing only.
field_evidence	Each populated field links message_id and short exact excerpt.	Message belongs to snapshot; excerpt occurs in source.
uncertainty	LOW MEDIUM HIGH plus conflicts and unresolved questions.	Not calibrated probability.
flags	Missing data conflicting facts truncation unsafe instruction unsupported language.	Allowlist codes.

Persist extraction, score, component breakdown, rubric, model, prompt and schema versions, input_version, requested and completed times, tokens, latency and safe failure metadata. Payload retention is minimized and approved separately. Output is never executable HTML SQL or tool instruction. Human adoption writes confirmed fields separately and audits; analysis history is preserved.

8.3 Deterministic score

Application code computes sum capped at 100 from validated evidence and confirmed facts, which take precedence. Model does not invent score. Unknown inputs earn zero; low score may represent missing data, not low customer quality.

Criterion	Points	Rule
Actionable intent	20	Explicit BUY RENT SELL INVEST.
Budget	20	Numeric amount or range and explicit currency.
Area	15	Customer stated location.
Property requirements	15	Property type 10 and explicit bedrooms 5.

Criterion	Points	Rule
Timeline	0 to 20	Within 30 days 20; 31 to 90 days 10; later or unknown 0. Use latest unambiguous stated timeline; relative periods anchor to source message time. Expired or conflicting timing earns 0 and is flagged.
Next step readiness	10	Explicit viewing callback or next action request.

Display components, missing evidence and rubric_version. Do not use protected traits inferred wealth style or contact completeness. Boundary tests and rubric approval required. Version any rule change and explicitly recompute while preserving prior results.

8.4 Guardrails and evaluation

Evaluate at least 100 approved deidentified inquiries covering English Arabic mixed language unknown currency rent periods conflicting facts injection and unsafe response cases. Proposed gate: 95% supported populated fields, zero critical tenant leakage and no automatic sends. Review language slices separately; unvalidated language remains an acknowledged limitation. Capture usefulness and unsafe feedback.

Adversarial text cannot invoke tools because none exist; server context isolation prevents unrelated retrieval. Withhold unsafe drafts and offer manual path. No invented listing availability discounts guaranteed returns visa legal or financing approval. Tenant disable and platform kill switch stop new jobs; cancel or withhold running results when required.

9 F 07 Reply suggestions

Generate with current lead context and optionally current analysis, visibly labeling stale analysis. Parameters: language, PROFESSIONAL or FRIENDLY tone, agent instruction up to 500 characters subject to system rules. Use confirmed facts; no live inventory presumed. Ask for missing details rather than invent facts.

Draft states GENERATED EDITED APPROVED REJECTED COPIED SUPERSEDED. Store original and editable text. Approval records actor time and input_version. Copy enabled only after explicit review of current version. Edit invalidates approval. New customer context makes draft stale, requiring regeneration or explicit freshness acknowledgement and review. Record rejected unsafe incorrect or unhelpful feedback.

Clipboard copy records copied event but no outbound message and no provider call. Separate Log external message saves actual sent text and user asserted time. There is no send button in MVP. Manual reply remains available even when AI fails.

10 F 08 Follow ups

Task fields: lead_id active assignee type CALL MESSAGE EMAIL VIEWING INTERNAL title due_at notes and state OPEN COMPLETED CANCELLED. Due and overdue are computed from OPEN and UTC due_at, not stored states. Managers choose members; AGENT assigned lead and self only. Title 150 and notes 2,000 proposed limits.

Create future task on active nonterminal nonarchived lead. Do not contact permits INTERNAL only. Complete requires summary and completion time; does not contact customer or alter status. Reschedule OPEN increments schedule_version and preserves audit; prior notice becomes obsolete. Do not reopen completed task; create new one.

Protected cron every proposed 5 minutes scans bounded 100 record batches. Atomic claims and unique key follow_up_id schedule_version event_type recipient prevent duplicate notices. Late scans catch up; no customer contact. Alert if oldest unprocessed due record exceeds 15 minutes. Recheck state and access before notification delivery.

Reassignment transfers OPEN tasks to new lead assignee after confirmation. Unassigned lead tasks enter manager queue and notify active OWNER and ADMIN separately. Completed and cancelled tasks do not create notices. Opening old notice shows latest authorized state.

11 F 09 Dashboard

Metric	Definition	Drill down
Total leads	Nonarchived leads created in selected local date range, within current scope.	Same cohort filter.
Qualified	Current QUALIFIED status within selected creation cohort.	Same cohort and status.
Follow ups due	OPEN tasks due at or before now on visible nonarchived leads, independent of lead creation dates.	Due task list.
Won	Current WON with won_at in selected range.	Outcome range.
Unassigned	Active nonterminal unassigned leads, manager only, independent of creation range.	Manager queue.
Pipeline	Current statuses within creation cohort.	Stage and cohort.

Default last 30 local calendar days including today; UTC boundaries end exclusive. Show scope and definitions. AGENT sees current assigned only; historical attribution later. RLS or explicit authorized scopes protect aggregates. Drill downs reconcile. Empty zero is distinct from unavailable error.

12 F 10 Notifications and F 11 Team

12.1 In app notices

Types LEAD_ASSIGNED FOLLOW_UP_DUE AI_READY AI_FAILED INVITE_ACCEPTED for inviter and MANAGER_REVIEW. Store tenant recipient type resource time read_at dismissed_at dedupe_key. Unique tenant recipient dedupe key. Own recipient read and dismiss only. Polling sufficient; push and email reminders later. Suppress sensitive previews if lead access changes. Open reauthorizes and shows neutral unavailable state when access lost. Retry notice failure without cancelling task.

12.2 Team operations

Managers see permitted member names emails roles ACTIVE DISABLED invitation and workload counts. Role or deactivation confirms workload replacement or manager queue. Disable membership immediately and transactionally reassign leads tasks notices and audit; large workload uses resumable operation with access revoked first. Repeated requests do not duplicate transfers. Never delete Auth user when disabling one membership. Owner manages ADMIN and AGENT; ADMIN manages AGENT only. Historical attribution stays stable under retention.

13 F 12 Audit and F 13 Privacy

13.1 Events and evidence

Activity shows capture assignment status message revision analysis draft review copy task archive restore. Immutable event fields: id tenant actor or system actor type entity UTC time request source sanitized old and

new values reason. Require reasons for closure duplicate override reopen ownership and do not contact clearing. No full messages passwords tokens or raw provider payloads in technical logs.

Critical mutations and audit insert commit together, or transactional outbox guarantees side effect retry. Approved backend functions alone write audit. Security events include denied high risk actions credentials membership support export privacy cases and job failures. Read follows agency and parent scope; users cannot update or delete evidence.

13.2 Retention deletion and support

Approve record class retention before live intake. Planning defaults: active leads until business purpose ends; archived review after 12 months; minimized AI snapshots 30 days; technical logs 30 days; audit metadata 12 months; raw imports removed within 24 hours. These are proposals, not legal rules. Document backup expiry and restored deletion replay separately.

Owner requests closure. Verified privacy cases record id scope reviewer hold if applicable execution and outcome. Disable processing and cancel jobs/tasks before purge. Purge or anonymize approved contacts messages and AI payloads; retain only justified minimized evidence. No agent permanent delete. Exceptional support requires scoped approval expiry purpose operator identity and audit. Server secret storage only; public browser config cannot contain privileged keys. High risk owner transfer closure credential rotation needs recent authentication and stronger release reviewed checks.

13.3 Security controls

Require HTTPS for browser, integration, database, and AI traffic. Use provider encryption at rest and separately encrypt intake secrets with controlled server keys. Validate server session identity using supported Auth verification, not an unverified client session object. Sign out revokes refresh capability and clears local tenant context. Membership authorization is checked on every request even while the identity session remains valid.

Proposed production baseline: OWNER and ADMIN enroll in TOTP multi factor authentication; AGENT enrollment is available. Owner transfer, agency closure, role elevation, and credential rotation require assurance level two and authentication within five minutes. Recovery is handled through a verified support procedure and cannot silently bypass role or owner protections. Confirm setup and recovery behavior during security review before release.

Use secure cookie and token handling appropriate to Supabase SSR, origin checks for mutations, a restrictive Content Security Policy, safe text rendering, and least privilege database grants. Never log Auth tokens, password reset links, signing secrets, or customer bodies in analytics. Rotate compromised credentials and invalidate affected integrations immediately. Review dependencies and high severity findings before release. Test session expiry, forged tenant selectors, role escalation, CSRF, stored script payloads, and privileged job scope as part of A 03 and A 24.

14 F 14 Reliability and error handling

AI outage never blocks manual lead work. Retain last successful analysis with age, disable affected action only, preserve user draft on network errors, and return request id rather than stack trace or secret.

Condition	System behavior	Recovery
Expired session	401 AUTH_REQUIRED, no mutation.	Sign in and restore safe draft.
Permission denied	403 for known permitted tenant action; 404 inaccessible resource.	Contact manager.
Validation	422 field paths and safe errors.	Correct inputs.

Condition	System behavior	Recovery
Concurrent edit	409 VERSION_CONFLICT, no partial save.	Compare current and local versions.
Idempotency conflict	409 changed hash, no new record.	Original payload or new event id.
Limit reached	429 rate or AI cap with retry information.	Wait or manual path.
AI refusal or invalid output	FAILED safe reason, no promoted result.	Manual response or explicit retry.
Dependency failure	503 retryable, retain idempotency.	Retry same operation.
Worker interruption	Lease expires and bounded worker resumes.	No user action normally.
Audit failure	Critical transaction rolls back.	Retry and report request id.

Proposed pilot limits: reads 60 per minute per user, mutations 30 per minute, AI submissions 10 per hour per user plus tenant daily cap, intake 60 per minute per integration. Shared durable limiter required, not function memory. Atomic estimated usage reservation reconciles actual tokens and releases unused amount; uncertain provider charges go to reconciliation.

Monitor latency HTTP errors job age AI failures token usage reservations due reminder lag outbox lag database health and intake rejects. Define incident triage credential rotation migration rollback backup restore and membership revocation runbooks. Verify BRD NF 01 to NF 10 on approved workload. No SLA implied by proposed targets.

15 Data model and ERD

Use UUID business ids, timestamptz UTC, numeric amounts, constrained enums. Every tenant table has tenant_id NOT NULL. Parent references use composite tenant_id and id uniqueness and foreign keys, preventing cross tenant links even in privileged workers. Tenant actor and immutable timestamps cannot be caller edited.

Entity	Key fields	Relationships and constraints
agencies	id name timezone locale state ai_enabled version	One to many tenant records; one active owner enforced transactionally.
profiles	user_id display_name preferences	References auth.users; self access or limited permitted team projection.
memberships	id tenant_id user_id role state	Unique tenant user; tenant safe assignment reference.
invitations	id tenant email role token_hash expiry state inviter	Single use; pending uniqueness tenant normalized email.
leads	id tenant contacts status assignee confirmed needs version context_version	Contact match indexes nonunique; archived and do_not_contact independent.
messages	id tenant lead direction channel body occurred_at provenance revision	Many per lead; customer changes increment context version.
message_revisions	id tenant message body actor time	Append only under lead scope and retention.

Entity	Key fields	Relationships and constraints
ai_jobs	id tenant lead kind state input_version lease attempts reservation	Durable unique request key and lease.
ai_analyses	id tenant lead job extraction score breakdown rubric model prompt	One per analysis job; many per lead; current only if context matches.
reply_drafts	id tenant lead job original working state version approval	One per reply job; edit invalidates approval; copy independent of send.
follow_ups	id tenant lead assignee type due_at state schedule_version version	Many per lead; computed due and overdue.
notifications	id tenant recipient type reference dedupe read_at	Unique tenant recipient dedupe; recipient only updates.
activity_events	id tenant actor type entity old_new reason request	Append only; parent and tenant scoped read.
integrations	id tenant type encrypted_secret key_version state	WEBSITE in MVP; manager controlled credential.
intake_events	id tenant integration external_event body_hash lead outcome	Unique tenant integration event.
imports and import_rows	id tenant actor state counts; row_index outcome lead	Unique import row; resumable results.
usage_reservations and usage_daily	tenant job reserved actual state; date units	Atomic caps; one reservation per job.
outbox	id tenant type minimal_payload state lease attempts	Transactional retryable side effects.
privacy_requests	id tenant case_id type state reviewer executed_at	Restricted operational evidence; minimized content.

15.1 Cardinality and deletion

Agency 1 to many Membership; Profile 1 to many Membership; Agency 1 to many Lead; Membership 1 to many assigned Lead with nullable assignment. Lead 1 to many Message Analysis Draft Follow up and Activity. AI Job 1 to zero or one result of its own kind. Integration 1 to many Intake events; event references zero or one created lead. Follow up has many versioned history events and deduplicated recipient notices.

Membership removal does not cascade business deletion. Privacy purge handles child content and deidentifies retained events by approved policy. Index tenant status created_at id, tenant assignee created_at, normalized contacts, worker state due_at, and tenant lead occurred_at id. Benchmark RLS joins and aggregates with realistic child volumes.

15.2 RLS and database writes

SELECT requires active membership and manager role or parent assignment. INSERT UPDATE have WITH CHECK and appropriate USING. Column grants triggers and approved functions protect immutable tenant role and state columns; row filters alone do not stop role escalation. Membership assignment outcomes and quota reservation use narrow transactional services.

User queries use authenticated user context. Service credentials bypass RLS and must not become generic user clients. Jobs resolve trusted tenant and parent ids and explicitly enforce scope. Lock down SECURITY DEFINER functions with fixed search_path and minimal grants; no caller chosen identity authority. Views and aggregates must preserve invoker security or explicit authorized scope.

16 API contracts

User /api/v1 endpoints require verified session and active tenant selector validated against membership. Intake and cron use separate credentials. JSON body proposed max 256 KB except bounded CSV. Apply origin and CSRF checks for cookie mutations. Responses: data with optional pagination; errors: code message field_errors request_id retryable. Idempotency binds tenant actor operation key and hash; replay rechecks access. Proposed replay retention 7 days pending source retry agreement.

Method and path	Contract	Permission
POST /agencies	name timezone locale; agency and membership result.	Verified user
GET /me/memberships	Own active tenant memberships.	Signed in
GET POST /leads	Filters cursor limit or create fields with optional idempotency.	Role scoped
GET PATCH /leads/{id}	Read detail or update allowed fields and expected_version.	Visible lead
POST /leads/{id}/status	status version outcome fields reason.	Visible lead
POST /leads/{id}/assignment	assignee or null version and task transfer confirmation.	Manager
POST /leads/{id}/archive or /restore	version reason cancellation confirmation.	Manager
GET POST /leads/{id}/messages	Cursor timeline or direction text occurred_at.	Visible lead
POST /leads/{id}/analysis	input_version idempotency; 202 job_id.	Visible lead
POST /leads/{id}/reply-drafts	language tone instruction input_version; 202 job.	Visible lead
GET /ai-jobs/{id}	state authorized result safe failure stale flag.	Current access
PATCH /reply-drafts/{id}	working_text version; edited state.	Current access
POST /reply-drafts/{id}/approve or /copy or /reject	version review acknowledgement or reason.	Current access
GET POST /follow-ups	Filters or lead assignee type title due_at notes.	Role scoped
POST /follow-ups/{id}/complete or /reschedule or /cancel	version summary new due_at or reason.	Role scoped
GET /dashboard	date range; values definitions and scopes.	All roles
GET /notifications and PATCH /notifications/{id}	Own list or read and dismiss.	Own recipient
GET POST /team/invitations	Permitted invite list or email and role.	Manager limits

Method and path	Contract	Permission
PATCH /team/members/{id}	role state version replacement.	Manager limits
POST /agency/transfer-owner	target_member recent_auth confirmation.	OWNER
POST /imports/leads and /imports/{id}/confirm	Upload preview and confirm valid rows; counts.	Manager
GET POST /integrations/website	Safe summary or credential; rotate revoke subactions.	Manager
POST /intake/{integration_id}/leads	Event id customer message source ref; timestamp and HMAC headers.	Website backend
GET /internal/cron/follow-ups and /internal/cron/jobs	Protected bounded worker scans.	Cron secret

16.1 Example exchanges

Create: {"full_name":"Sample Buyer","email":"buyer@example.com","initial_message":"Looking for a two bedroom in Dubai Marina for AED 1500000 within 30 days"}. Tenant creator timestamps and score remain server controlled.

HTTP 201: {"data":{"id":"lead_uuid","status":"NEW","version":1,"duplicate_review":false}}. Analyze HTTP 202: {"data":{"job_id":"job_uuid","state":"QUEUED"}}. Invalid range HTTP 422: {"error":{"code":"VALIDATION_FAILED","message":"Correct highlighted fields","field_errors":{"budget_max":"Must be at least budget_min"},"request_id":"req_uuid","retryable":false}}.

17 Validation and configuration

Field	Rule	Failure behavior
Name	Trim Unicode text 2 to 120.	422 field message.
Email	Valid syntax trim lowercase key max 254.	Reject; no deliverability claim.
Phone	International country code normalized; 7 to 15 digits baseline.	Ask code, do not guess.
Contact	At least one valid email or phone.	No partial create.
Message	Plain text 1 to 10,000, not whitespace only.	Retain user draft; escape HTML.
Budget	Nullable decimal >=0 min <= max; currency if amount present.	No implicit conversion.
Currency period	ISO currency allowlist; MONTH YEAR TOTAL UNKNOWN.	Reject unsupported; preserve unknown.
Locations	Up to 5 each <=120 characters.	Trim deduplicate list.
Bedrooms	Integer 0 to 50; studio 0 only when confirmed.	Reject invalid number.
New task due	Valid UTC ISO from timezone aware input, future.	Block invalid creation.
Assignee	Active same tenant; agent self.	Generic invalid member.

Field	Rule	Failure behavior
Version	Positive integer equals current.	409 conflict.
Lost OTHER	Reason text 5 to 500.	Block transition.
Won	Summary 5 to 1,000 and date not future.	Block transition.
Invitation	Verified email matching valid unused token and available seat.	Generic safe failure.
Ownership	One owner active target recent authentication.	Reject stale or incomplete.
Do not contact	No outreach; manager reason to clear.	Explicit explanation.

Configurable limits and approved retention are stored separately. No setting disables isolation audit contact preferences or mandatory review. Server validation remains authoritative. Locale formatting is display only; API uses canonical decimals and UTC.

18 End to end workflows

18.1 Inquiry to outcome

1 Website backend signs stable event. 2 Validate and persist lead inbound message audit. 3 Manager assigns and agent notified. 4 Durable analysis extracts evidence and computes score. 5 Agent confirms facts and generates draft. 6 Edit approve copy send externally and log actual reply. 7 Create task and confirm FOLLOW_UP. 8 Due scan notifies. 9 Complete or reschedule, then explicitly close outcome.

Replay returns original; duplicates flag review; AI failure leaves manual route; new text makes results stale; failed notices retry; closed and do not contact leads suppress outreach.

18.2 Deactivation

Manager previews workload, selects replacement or queue, confirms. Server verifies role and version, disables membership immediately, transfers workload transactionally or resumably, suppresses old notices, notifies new assignees and audits counts. Repeat is idempotent.

18.3 AI recovery

Reserve usage and snapshot permitted context. Transient error retries within cap. Exhaustion fails safely and reconciles reservation. Last analysis stays visible with age. Explicit authorized retry creates new job. Late result cannot override newer or cancelled context.

19 Roadmap specification

19.1 F 15 Billing

Phase 2 separates provider state from effective entitlements. Proposed TRIAL ACTIVE PAST_DUE SUSPENDED CANCELLED need approved dates and grace policies. OWNER uses provider hosted checkout and portal. Signed events deduplicate and resolve by effective state rather than arrival alone; periodic reconciliation handles missing events. Limits server enforced; billing failure never deletes records. Approve read only access, exports, retention, tax, invoices and refunds first.

19.2 F 16 Integrations

Official WhatsApp and email require tenant scoped credentials OAuth least privilege contact preference template and outreach policy checks where applicable verified callbacks retries deduplication delivery reconciliation and revoke. Review remains default gate. CRM and portal sync needs contracts field mapping source of truth conflicts tombstones and official API access. Listing retrieval later uses tenant authorized data with source and freshness; calendars need conflict and timezone rules. n8n cannot bypass permission checks.

19.3 F 17 Reporting

Phase 2: manager authorized CSV source stage cohort workload and usage reports. Audit exports, sanitize spreadsheet formula values, expire downloads. Phase 3 attribution only after reliable outcomes and channel timestamps. Define cohort dates current versus historical state reopened duplicates archives timezone and reassignment attribution.

20 Acceptance tests and traceability

Test with two agencies each with OWNER ADMIN and two agents, plus shared user with different roles. Include UI API and direct database negative attempts. Evidence records environment build fixtures result and reviewer.

A 01 F 01 BR 01

Verified user creates exactly one agency and owner; retry has no duplicate.

A 02 F 01 F 11 BR 01 BR 11

Valid invitation creates one membership; expired consumed mismatched email and revoked token fail without disclosure.

A 03 F 02 F 13 BR 02 BR 13

Tenant A cannot read or mutate B leads children jobs metrics notifications through UI API or user database access.

A 04 F 02 BR 02

AGENT cannot see other assigned or unassigned records, child data or aggregate contributions.

A 05 F 02 F 11 BR 11

ADMIN cannot promote self or manage owner/admin; owner transfer never leaves zero or two owners.

A 06 F 03 BR 03

Missing contact and invalid budgets return fields and no partially created lead message or audit.

A 07 F 03 BR 03

Same signed event delivered twice creates one result; different hash same id returns 409.

A 08 F 03 BR 03

Mixed CSV valid invalid duplicate rows reconcile and resumed job inserts each row at most once.

A 09 F 03 F 04 BR 03 BR 04

Restricted duplicate reveals no other identity and creates manager review flag.

A 10 F 04 BR 04

CONTACTED without log FOLLOW_UP without task and WON without summary are blocked.

A 11 F 04 F 08 BR 04 BR 08

Terminal or archive cancels tasks atomically after confirmation; reopen does not revive them.

A 12 F 05 F 07 BR 05 BR 07

Copied draft is not outbound message; manual outbound log never claims delivery.

A 13 F 06 BR 06

Unknown and conflicting facts remain unknown or flagged, evidence points to source, score matches every rubric boundary.

A 14 F 06 F 07 BR 06 BR 07

Injection exposes no unrelated records or secrets, runs no tools; unsafe drafts withheld.

A 15 F 06 F 14 BR 06 BR 14

Timeout refusal invalid schema safely fail with bounded retries; CRM works and reservations reconcile.

A 16 F 06 F 07 BR 06 BR 07

New context makes late result stale; approved draft edit invalidates review and copy gate.

A 17 F 04 F 07 F 08 BR 07 BR 08

Do not contact blocks drafts and tasks, cancels outreach; clear requires manager reason.

A 18 F 08 F 10 BR 08 BR 10

Repeated delayed scan yields one notice per recipient schedule; reschedule suppresses old schedule and catches missed work.

A 19 F 09 BR 09

Dashboard and drill downs match date timezone role fixtures; unauthorized records never contribute.

A 20 F 10 F 11 BR 10 BR 11

Deactivation blocks next request, work stays manager visible and old notices hide inaccessible content.

A 21 F 12 BR 12

Critical changes write immutable scoped event; audit failure rolls back mutation.

A 22 F 13 BR 13

Approved deletion handles children jobs retention and backup restore deletion replay.

A 23 F 14 BR 14

Reference load recovery and backup exercise meet approved NF targets with recorded results.

A 24 F 01 to F 14

Keyboard forms responsive layout and retained input on recoverable errors pass core UAT.

20.1 Coverage matrix

Business	Functional	Acceptance
BR 01	F 01	A 01 A 02 A 24
BR 02	F 02	A 03 A 04 A 05
BR 03	F 03	A 06 A 07 A 08 A 09
BR 04	F 04	A 09 A 10 A 11 A 17
BR 05	F 05	A 12
BR 06	F 06	A 13 A 14 A 15 A 16
BR 07	F 07	A 12 A 14 A 16 A 17
BR 08	F 08	A 11 A 17 A 18
BR 09	F 09	A 19
BR 10	F 10	A 18 A 20
BR 11	F 11	A 02 A 05 A 20
BR 12	F 12	A 21
BR 13	F 13	A 03 A 22
BR 14 and NF 01 to NF 10	F 14 and cross cutting design	A 15 A 23 A 24 and NF measurements
BR 15 to BR 17	F 15 to F 17	Future release acceptance required

21 Delivery readiness and open decisions

Deliver slices: tenant permissions foundation, validated intake and lifecycle, conversations and tasks, AI jobs and reviewed drafts, dashboard and notices, administration and audit, hardening and UAT. Each slice includes migration authorization validation errors and meaningful verification; tenant safety is not deferred.

- Resolve BRD D 02 processing D 03 retention before live intake, D 05 score D 07 visibility and D 09 targets before release acceptance.
- Provision domains Auth email credentials backups suitable cron tier AI quota and operations ownership.
- Approve controlled reasons phone policy data dictionary review wording and sample evaluation set with agency.
- Future billing and channels require provider specific state callbacks permission and acceptance change sets.

Risks and owners follow BRD section 15: isolation needs negative tests, outage needs durable jobs and fallback, misinformation needs evidence and review, source quality needs reconciliation, and reminders need catch up scans.

22 Technical references and approval

Platform references checked 5 October 2026. Application rules and numeric targets are product design decisions. Recheck documentation and pinned versions during implementation.

- Supabase Row Level Security https://supabase.com/docs/guides/database/postgres/row-level-security
- OpenAI Responses create https://developers.openai.com/api/reference/resources/responses/methods/create
- Vercel Managing Cron Jobs https://vercel.com/docs/cron-jobs/manage-cron-jobs

Approver	Date and signature	Evidence
Engineering lead	To be completed	Architecture contracts migrations
QA lead	To be completed	A 01 to A 24 and NF results
Product Owner	To be completed	Scope and decision alignment
Agency representative	To be completed	Pilot UAT
Security and privacy reviewers	To be completed	Isolation processing retention